

FINAL PRE-LAUNCH RISK AUDIT

HAULWAY

Public Launch Readiness Report & Implementation Roadmap

Edmonton, Alberta, Canada

Architecture, privacy, security, payments, operations,
driver risk, production readiness and launch controls

LAUNCH DECISION

NOT READY FOR PUBLIC LAUNCH. Do not accept real customers, real property, driver applications, or money until all launch blockers are closed and independently re-tested.

Prepared as a read-only launch-gate assessment. No production or repository changes were made. This is a risk audit, not legal advice.

Report guide

Section	Purpose
1. Executive launch gate	Decision, material facts, and controls that passed
2. System and data flow	Architecture, personal information, access, and deletion
3. Risk register	Fifteen findings with evidence, remediation, owners, and tests
4. Implementation roadmap	Critical path, eight-week plan, workstreams, and go/no-go gates
5. Operating frameworks	Prohibited items, property claims, failure behavior, and incident response
6. Governance inventories	Retention matrix, third parties, professional reviews, and checklist
Appendix	Technical validation and primary official sources

Audit basis

- Repository main branch and deployed Netlify build at commit 0c53682.
- Live Netlify application and security headers; production Supabase project configuration; database/storage aggregate state; SMS outbox delivery state; and custom-domain response.
- Source review of authentication, authorization, APIs, database migrations, file uploads, sessions, SMS, payments, customer flow, and operator flow.
- Build, TypeScript, lint, source tests, dependency audit, tracked-secret scan, and targeted production read-only checks.
- Current official Alberta and Canadian privacy, consumer, licensing, transport, tax, employment, WCB, SMS, marketing, and payment-security guidance.

LIMITATION

No destructive testing or production mutation was performed. Insurance, corporate, licensing, and external legal documents were not provided; an unresolved item means it was not evidenced during the audit, not necessarily that it does not exist elsewhere.

1. Executive launch gate

Decision

NOT READY FOR PUBLIC LAUNCH

The application compiles and contains thoughtful security controls, but the live service cannot safely accept the first real customer. The live-dashboard review converted several code-only concerns into confirmed production failures.

Confirmed launch blockers

- Customer SMS authentication is required by the app, but Phone Auth is disabled in production Supabase.
- Fifty-two request-update SMS messages are pending with zero delivery attempts; the oldest has been waiting since August 14.
- No Privacy Policy, Terms, driver agreement, prohibited-items policy, claims process, refund policy, support contact, privacy contact, or deletion process is present.
- One six-digit operator PIN grants access to every customer address, photo, message, and payment state; there is no MFA, named account, RBAC, driver assignment, or audit trail.
- Production Supabase reports no backups, no registered migrations, and no database branches.
- d-load.ca resolves to Netlify but returns Site not found because no custom domain is attached to the current project.
- Payments use a hard-coded personal email address and manual payment confirmation without transaction, receipt, refund, tax, or reconciliation records.
- Driver identity, licence, vehicle, insurance, commercial-use coverage, WCB and contractor status, and transport compliance are not implemented or verified.
- No proof-of-pickup, proof-of-delivery, change-order, accident, cargo-loss, or damage-claim workflow exists.

Controls already in place

Control	Result
Source/deploy integrity	Repository and production match commit 0c53682; worktree was clean.
Build quality	Production build, TypeScript, lint, and nine source tests passed.
Dependencies	npm audit --omit=dev reported zero known production vulnerabilities.
Secrets	No committed secret value found; only .env.example is tracked.
Database access	RLS enabled; anon/authenticated table access revoked; service role remains server-side.
Customer authorization	Customer routes scope jobs to customer_id; media is re-authorized and signed for 60 seconds.
Storage	job-media bucket is private with a 25 MB object limit.
Sessions/mutations	High-entropy tokens, hashed server values, HttpOnly/SameSite cookies, origin checks, request limits and rate limiting.
Response hardening	CSP, HSTS, no-sniff, frame denial, referrer/permissions policy and no-store APIs are live.

2. System and personal-data flow

CUSTOMER	NETLIFY / NEXT.JS	SUPABASE	OPERATOR / PROVIDERS
Name + phone Address + schedule Photos/videos Messages Quote decisions	UI + API Session cookies Authorization Signed upload plans SMS worker	Auth: OTP disabled Postgres: jobs/messages/sessions/outbox Private Storage: media US West region	Global operator sees every submitted job Twilio receives phone/message when configured Cash/Interac occurs outside app

Where personal information lives

Information	Location / transmission	Access	Deletion today
Name + phone	Supabase customers; phone to Auth	Customer + global operator	None
Addresses, access details, schedule	Jobs table and 24-hour browser draft	Customer + global operator	None
Photos/videos	Private Supabase Storage; metadata in job_media	Customer + global operator via signed URL	Abandoned-draft best effort only
Messages	messages table; operator text may be copied to SMS	Customer, global operator, Twilio	None
Sessions	HttpOnly cookie; SHA-256 token hash in sessions	Browser/server	Expired row cleanup only on future session creation
Quote/payment/rating	jobs and system messages	Customer + global operator	None
SMS content	sms_outbox then Twilio	Server/provider	None
Card data	Not collected	None	Not applicable
Driver documents	Not implemented	None	Not applicable

MINIMIZATION RULE An assigned driver should receive only the customer data reasonably necessary for that job, only when needed, and for only as long as needed.

3. Risk register

F01 Production customer authentication is nonfunctional	BLOCKER - DO NOT LAUNCH
Why it matters	Real customers cannot receive the required verification code, so the booking flow is unavailable.
Evidence	Live /api/auth/me reports otpRequired=true; production Supabase shows Phone Disabled and no Auth users. The app calls signInWithOtp.
Recommended solution	Enable and fund a Canadian-capable phone provider, verify fraud controls, add configuration health checks, and delete the unverified fallback endpoint.
Required changes	Code: Yes Policy/docs: SMS/privacy notice and consent records Professional review: Privacy/legal review recommended
Verification	Register a new production test number; verify delivery, one-time use, expiry, throttling, logout, and rejection of the direct route.
F02 Request-update SMS delivery is broken	BLOCKER - DO NOT LAUNCH
Why it matters	Driver acceptance, ETA, arrival, quote, completion and payment updates are promised but not delivered.
Evidence	Production contains 52 pending outbox rows, zero provider IDs and zero attempts; oldest is August 14. The scheduled worker exits when credentials are incomplete.
Recommended solution	Configure sender and credentials; add queue-age alarms, health failure, delivery receipts, dead-letter handling, consent evidence and STOP reconciliation.
Required changes	Code: Yes Policy/docs: Transactional/marketing, consent, frequency and opt-out policy Professional review: CASL/privacy review required
Verification	Send every event type to controlled Canadian numbers; prove delivery, retry, STOP suppression, queue drainage and alerting.
F03 No privacy-management program	BLOCKER - DO NOT LAUNCH
Why it matters	Names, phone numbers, exact addresses, property photos and messages are processed without meaningful notice, rights or deletion.
Evidence	No policy, privacy contact, collection notice, consent ledger, access/correction flow, deletion flow or retention job. Supabase and Netlify process data in the United States.
Recommended solution	Designate a privacy officer; publish an accurate policy; document purposes, vendors/countries, rights, retention, safeguards, complaints and breach response.
Required changes	Code: Yes Policy/docs: Privacy Policy, internal privacy program, request procedures Professional review: Alberta privacy professional and lawyer required
Verification	Trace each field to a disclosed purpose; test access, correction and deletion; verify provider deletion and run a breach tabletop.

F04 No customer contract or Internet-sales disclosure	BLOCKER - DO NOT LAUNCH
Why it matters	A quote can be accepted without business identity, taxes, scope, additional-charge, cancellation, refund, claims or prohibited-item terms.
Evidence	The quote screen contains only amount, Accept and Decline. After acceptance, self-service cancellation is removed.
Recommended solution	Create counsel-reviewed Terms and specific cancellation, refund, failed-pickup, waiting, access, heavy-item, additional-charge, prohibited-item, misuse and claims rules. Retain the accepted version.
Required changes	Code: Yes Policy/docs: Terms plus eight operational policies Professional review: Alberta lawyer required
Verification	Customer can review, retain, correct, decline and later retrieve the exact contract accepted.

F05 No safe driver/marketplace authorization model	BLOCKER - DO NOT LAUNCH
Why it matters	Every operator can see every customer address, phone, photo, note, message and payment state.
Evidence	canAccessJob returns true for any operator and the operator list returns every finalized request. There is no driver or assignment table.
Recommended solution	Separate admins from drivers; add named identities, approval and suspension, atomic assignment, least-privilege fields and post-job access expiry.
Required changes	Code: Yes Policy/docs: Driver agreement, confidentiality, conduct, privacy and termination Professional review: Lawyer, privacy, insurance and transport review required
Verification	Driver A cannot enumerate Driver B jobs; unassigned/rejected drivers receive no customer data; expired assignment access is revoked.

F06 Insurance, licensing and transport readiness is unverified	BLOCKER - DO NOT LAUNCH
Why it matters	Hauling creates commercial-auto, cargo, property, injury, dangerous-goods and worker-classification exposure.
Evidence	No licence, registration, vehicle, commercial-use insurance, WCB, cargo-securement, training or regulatory verification model exists.
Recommended solution	Verify city licensing, insurer-approved operating model, vehicles, operating area, WCB, carrier thresholds, cargo rules and periodic re-verification before driver activation.
Required changes	Code: Yes if drivers launch Policy/docs: Driver agreement and safety manual Professional review: Insurance broker, transport specialist, employment/WCB lawyer and accountant required
Verification	Expired or unverified drivers cannot accept jobs; revocation is immediate; re-verification alerts are tested.

F07 Payment and accounting architecture is inadequate	BLOCKER - DO NOT LAUNCH
Why it matters	The system cannot reliably prove who was paid, taxes, refunds, duplicate payments or disputes.
Evidence	A personal Gmail address is hard-coded; the operator clicks Mark paid; no transaction, invoice, receipt, refund, fee, payout or reconciliation record exists.
Recommended solution	Use a business-controlled destination; add immutable quote versions, change-order acceptance, transaction/reconciliation records, receipts, tax, refunds and role-restricted adjustments.
Required changes	Code: Yes Policy/docs: Pricing, tax, payment, refund, chargeback and payout policies Professional review: Accountant and Alberta lawyer required
Verification	Every completed job reconciles to one receipt and bank/provider transaction; retries do not duplicate; refunds are audited.
F08 No production backup, staging or migration assurance	BLOCKER - DO NOT LAUNCH
Why it matters	A bad migration, operator error or key compromise could permanently lose jobs, evidence and accounting records.
Evidence	Supabase Free plan reports Last backup: No backups, Last migration: No migrations and no database branches. One production project is used.
Recommended solution	Enable verified backups/PITR appropriate to risk; create isolated staging; apply tracked migrations through CI; document rollback and restore.
Required changes	Code: Deployment/migration changes Policy/docs: Backup, restore, release and rollback runbooks Professional review: Privacy/accounting retention review recommended
Verification	Restore into an isolated environment and prove database, media, messages and schema consistency against defined RPO/RT0.
F09 Privileged access is not launch-grade	BLOCKER - DO NOT LAUNCH
Why it matters	One six-digit PIN protects the full customer dataset and all operational controls.
Evidence	There is one global operator, no MFA, named account, RBAC, recovery governance, access review or action audit trail. Rate limiting is per IP.
Recommended solution	Implement named accounts, mandatory MFA, RBAC, secure recovery, device/session controls, offboarding, login alerts and immutable action audit events.
Required changes	Code: Yes Policy/docs: Privileged-access, device, onboarding and offboarding policies Professional review: Privacy/security review recommended
Verification	Removed staff lose all sessions; MFA is enforced; sensitive actions record actor, reason, time, request ID and before/after state.

F10 Job-state transitions are race-prone	HIGH - FIX BEFORE LAUNCH
Why it matters	Two tabs can read the same state and issue conflicting last-write-wins actions or duplicate messages.
Evidence	Routes check status first, then update only by job ID. There is no expected-version compare, transactional command or idempotency key.
Recommended solution	Move lifecycle commands into transactional database RPCs with expected state/version, idempotency and event records. Add structured cancellation, no-show, address-change and abort paths.
Required changes	Code: Yes Policy/docs: Cancellation, change-order, no-show and additional-charge rules Professional review: Lawyer/operations review
Verification	Parallel acceptance, quote, arrival, completion, cancellation and payment tests produce exactly one valid transition and event.
F11 No defensible damage, cargo-loss or delivery-evidence process	BLOCKER - DO NOT LAUNCH
Why it matters	The business cannot reliably investigate pre-existing damage, false non-delivery, loss, driver damage or injury.
Evidence	Only customer pre-job media exists. No driver inspection, pickup/delivery proof, recipient confirmation, evidence lock, insurer escalation or claim record exists.
Recommended solution	Implement condition capture, pickup custody, delivery proof, claim intake, evidence preservation, investigation, insurer escalation, resolution and legal holds.
Required changes	Code: Yes Policy/docs: Claims, evidence and safety policies Professional review: Alberta lawyer and insurance broker required
Verification	Run a mock claim from intake through evidence, driver response, insurer referral, decision, communication, retention and appeal.
F12 Upload and retention controls are incomplete	HIGH - FIX BEFORE LAUNCH
Why it matters	Property media may contain faces, interiors, documents, geolocation metadata or malicious files and currently remains indefinitely.
Evidence	MIME/extension/size checks and private links are good, but metadata is client-supplied; no magic-byte validation, scanning, re-encoding, EXIF stripping, quarantine or lifecycle cleanup exists.
Recommended solution	Add server file identification, scanning/quarantine, safe re-encoding, metadata stripping, lifecycle expiry, orphan cleanup and media-safe response headers.
Required changes	Code: Yes Policy/docs: Photo purpose, visibility, content and retention Professional review: Privacy/security review recommended
Verification	Mislabeled and malicious files are rejected; EXIF is removed; unauthorized access fails; expired/orphan objects are purged.

F13 Monitoring, support, incident response and tests are insufficient	HIGH - FIX BEFORE LAUNCH
Why it matters	Authentication and SMS remained broken without launch alarms; real incidents could remain invisible until a complaint.
Evidence	No error tracker, uptime monitor, queue alert, security alert, support channel or incident runbook. Existing tests mostly assert that source strings exist rather than exercising behavior.
Recommended solution	Add redacted structured logs, request IDs, synthetic auth/booking tests, error tracking, uptime and queue monitoring, on-call ownership, behavioral E2E tests and visible contacts.
Required changes	Code: Yes Policy/docs: Incident and customer-support runbooks Professional review: Privacy/lawyer review for notification and evidence
Verification	Simulated OTP, SMS and database failures alert an owner; quarterly restore and incident tabletops are documented.
F14 Custom domain and release topology are incomplete	BLOCKER - DO NOT LAUNCH
Why it matters	A broken advertised domain causes lost trust, customer confusion and callback/policy inconsistencies.
Evidence	d-load.ca returns Netlify Site not found. haulway9 has no custom domain or aliases; www is unresolved. The Netlify alias serves the current commit over HTTPS.
Recommended solution	Attach apex and www, select a canonical host, verify DNS/TLS, redirect aliases, update metadata/auth URLs and retire obsolete deployments.
Required changes	Code: Possibly canonical-host configuration Policy/docs: Publish policies/contacts on canonical domain Professional review: No
Verification	Apex and www pass HTTPS/certificate tests, redirect consistently and every legal/auth/media URL uses the canonical host.
F15 Public claims overstate working functionality	HIGH - FIX BEFORE LAUNCH
Why it matters	The site promises SMS verification and automatic updates while both systems are disabled or stalled.
Evidence	Registration displays SMS verified; booking receipt says updates will be sent; operator screen says customer updates automatically.
Recommended solution	Fix the services before restoring claims. Maintain evidence for future insured, licensed, background-checked, guaranteed, secure or professional-driver claims.
Required changes	Code: Yes Policy/docs: Marketing approval/evidence process Professional review: Lawyer review recommended
Verification	Every public statement has dated supporting evidence and honest degraded-service copy.

4. Implementation roadmap

Roadmap objective

Move Haulway from a functional prototype to a controlled Edmonton pilot, then to a public service only after all blockers are closed. Dates are sequence estimates, not promises; professional review and provider lead times control the critical path.

RULE	Public intake stays closed until the final go/no-go gate. Pilot jobs must exclude hazardous, unknown, regulated, unusually heavy and high-value items until the related specialist controls are approved.
-------------	---

Critical path

1	Auth + SMS	2	Legal/privacy/insurance decisions	3	Driver/payment/claims controls	4	Backups + monitoring + E2E	5	Controlled pilot	6	Public launch gate
---	------------	---	-----------------------------------	---	--------------------------------	---	----------------------------	---	------------------	---	--------------------

Eight-week launch plan

Phase / target	Outcome	Primary work	Exit gate
0. Freeze + ownership Day 0-2	One accountable launch program	Close public intake; name launch, security/privacy, operations and incident owners; freeze scope; create blocker tracker; confirm corporate/insurance/licence document locations.	Owner and due date on every blocker; no real bookings accepted.
1. Identity + communication Days 1-7	Customers and operators can authenticate and receive reliable updates	Enable Supabase Phone; remove direct-auth route; configure app SMS; implement consent/STOP ledger; queue monitoring; named admin accounts; MFA; session revocation.	Production OTP and every SMS event pass; queue stays near zero; MFA required.
2. Legal + operating foundation Weeks 1-3	Rules reflect the real service	Privacy program; Terms; driver agreement; cancellation/refund/claims/prohibited-items/AUP; business licence; insurance and vehicle requirements; GST/accounting decision; contractor/WCB review.	Signed professional approvals and published versioned policies.
3. Core product reliability Weeks 2-5	Jobs, money and evidence fail safely	Driver/assignment RBAC; atomic versioned lifecycle commands; idempotency; structured cancellations/change orders; business payment ledger/receipts/refunds; pickup/delivery proof; claim cases; media scanning/retention.	Concurrency, authorization, payment and claims suites pass.
4. Production platform Weeks 3-6	Recoverable and observable production	Attach d-load.ca; isolated staging; tracked migrations; backups/PITR; restore test; redacted logs; error/uptime/queue monitoring; alert rota; rollback; dependency/security pipeline.	Restore meets RPO/RTO; canonical domain works; synthetic tests and alerts are green.
5. Controlled pilot Weeks 6-7	Evidence from limited real operations	5-10 pre-approved low-risk jobs; verified internal drivers only; manual dispatch oversight; daily reconciliation; claim/incident drill; support coverage; collect operational metrics.	No unresolved severity-1 incidents; 100% auth/SMS/payment reconciliation; pilot retrospective approved.
6. Final public gate Week 8+	Deliberate launch decision	Independent security review; counsel/privacy/insurance/accounting/transport sign-off; production checklist; rollback rehearsal; launch-day monitoring and support staffing.	Zero open blockers and documented go/no-go approval.

Roadmap workstreams and owners

Workstream	Accountable role	First deliverables	Dependencies
Launch governance	Founder / launch manager	Blocker tracker, scope freeze, decision log, go/no-go forum	All workstreams
Identity + security	Security engineer	Phone OTP, MFA, named accounts, RBAC, audit events, session controls	Supabase/Twilio accounts
Messaging	Backend engineer + operations	SMS credentials, consent/STOP, delivery receipts, queue alerts, fallback support	Phone provider, privacy language
Privacy + legal	Privacy officer + Alberta counsel	Privacy Policy, Terms, driver agreement, notices, retention, request process	Actual business/driver/payment model
Driver + safety	Operations lead	Eligibility, insurance/vehicle verification, assignments, suspension, safety manual	Broker/transport/WCB advice
Payments + tax	Finance owner + accountant	Business destination, quote versions, receipts, ledger, refunds, reconciliation	Business entity/GST decisions
Claims + evidence	Operations + insurer	Pickup/delivery proof, claim case, insurer escalation, legal hold	Terms, insurer requirements
Platform reliability	Lead engineer	Atomic states, idempotency, staging, migrations, backups, restore, monitoring	Approved product rules
Quality + release	QA/release owner	E2E, concurrency, security tests, pilot scripts, rollback rehearsal	All technical work

Priority backlog

Priority	Must complete	Can wait
P0 - launch blockers	F01-F09, F11, F14: authentication, SMS, privacy/terms, driver model, insurance/licensing, payments, backups, admin MFA/RBAC, claims, domain	Nothing in P0 may be deferred for public intake
P1 - pre-launch hardening	F10, F12, F13, F15: atomic lifecycle, upload safety/retention, monitoring/support/E2E, accurate claims	Nonessential UX polish and growth features
P2 - post-pilot	Advanced analytics, route optimization, automated driver payouts, expanded service categories	Only after operating metrics and incident trends are stable

Launch scorecard

Metric	Pilot threshold	Public launch threshold
Open launch blockers	0	0
OTP success	>= 98% controlled attempts	>= 98% rolling 7 days
Transactional SMS	100% accounted for	>= 99% delivered or known provider outcome
Authorization tests	100% pass	100% pass + independent review
Payment reconciliation	100% of pilot jobs	100% daily reconciliation
Backup restore	One full successful rehearsal	Within approved RPO/RTO
Critical alerts	All synthetic failures page owner	24/7 or defined staffed operating coverage
Policies/sign-offs	All published and versioned	All professional approvals current

30 / 60 / 90 day execution view

Window	Focus	Definition of done
Day 0-30	Stop exposure and establish foundations	OTP/SMS working; direct auth removed; named MFA admin; policies in review; insurance/licensing/tax decisions documented; d-load.ca working; backups and staging established.
Day 31-60	Make operations and data reliable	Driver assignment/RBAC; atomic state machine; payment ledger; claims/POD; media lifecycle; monitoring; behavioral E2E; restore and incident drills.
Day 61-90	Controlled pilot and deliberate scale	Limited low-risk pilot, daily reconciliation, incident metrics, independent security review, professional sign-offs, zero blockers, documented public go/no-go.

Go / no-go decision package

- A signed blocker register showing evidence and retest for every F01-F15 item.
- Current Privacy Policy, Terms, Driver Agreement, Cancellation/Refund, Claims, Prohibited Items and Acceptable Use versions.
- Insurance, business-licence, transportation, WCB/contractor and GST/accounting decisions.
- Production diagrams, vendor inventory, access list, backup/restore proof, migration list and rollback runbook.
- Independent security report and authorization/concurrency/E2E test results.
- Pilot results: job reconciliation, SMS delivery, support cases, incidents, claims, cancellations and customer outcomes.
- Founder/launch, engineering, operations, privacy/legal, insurance and finance sign-off.

NO-GO TRIGGERS

Any open blocker; disabled OTP or messaging; failed restore; unknown privileged access; unresolved insurance/licence requirement; missing customer/driver agreement; unreconciled money; critical security test failure; or unsupported marketing claim.

5. Operating risk frameworks

Prohibited and restricted items

This is a conservative interim framework, not a determination that every item is legally prohibited.

Tier	Items	Interim treatment
Temporarily prohibit	Explosives; firearms/ammunition; illegal drugs; controlled substances; biohazards; medical waste; human remains; animals; leaking, unlabelled or unknown chemicals; illegal waste	Reject until counsel, insurer and regulatory specialist approve a specific workflow
Regulated / specialist only	Fuel; propane; hazardous chemicals; paint; large batteries; refrigerants/appliances; asbestos; contaminated construction waste	Not through ordinary drivers; require classification, trained carrier, containment, documents, insurance, destination and emergency plan
Pre-approval / high risk	Extremely heavy/oversized; cash; jewellery; artwork; high-value or irreplaceable property; sensitive documents	Declared value, suitability, insurer approval, handling plan, evidence and written acceptance
Ordinary	Furniture; standard appliances with no leak/hazard; non-hazardous junk; normal household goods	Normal workflow after declarations and pickup inspection

Damage and cargo-claim workflow

Stage	Required control
Before acceptance	Customer condition photos, description, known damage, approximate value when appropriate, fragile/special handling, prohibited-item confirmation
At pickup	Assigned-driver inspection, timestamped photos, exceptions, customer acknowledgement, item count and custody confirmation
At delivery	Delivery photos, timestamp, recipient confirmation, proof of delivery, exceptions and refusal/non-delivery path
Claim intake	Job ID, affected item/property, description, evidence, injury/safety triage and insurer trigger
Investigation	Freeze relevant records, preserve originals/logs, driver response, evidence comparison and documented access/decisions
Resolution	Insurer/counsel escalation, written result, approved payment/refund, appeal path, retention and legal hold

Logical failure tests

Scenario	Current risk	Required safe behavior
Concurrent accept/quote/complete	Stale read + unconditional update	Expected-version transaction + idempotency
Two drivers accept	No driver model	One atomic assignment
Cancel/change after pickup	No structured path	Reason, evidence, fee rule, re-quote and notice
Connection drops after mutation	Unknown outcome	Idempotent retry and reconciliation
False completion/non-delivery	Two confirmations but no evidence	Pickup/delivery proof and dispute state
SMS outage	Queue stalls silently	Queue alert, support fallback and reconciliation
Database outage	Generic error; state/event not atomic	Transactional event, retry and runbook
Account deletion during active job	No deletion flow	Controlled deferral, resolution and minimal retention

Incident-response plan

Detect -> Contain -> Preserve evidence -> Escalate -> Notify appropriate parties -> Resolve -> Document -> Prevent recurrence

Incident	Immediate containment
Data breach / stolen admin	Revoke sessions and keys; lock privileged access; preserve logs; assess affected data; involve privacy lead/counsel
Payment fraud	Freeze payment/payout state; preserve bank/provider evidence; contact business bank/provider
Accident / injury	Emergency services first; stop job; preserve facts; notify operations and insurer
Property damage / cargo loss	Secure property; lock evidence; notify insurer; open claim case
Threat / harassment	Separate parties; disable contact/account where safe; preserve messages; call emergency services for immediate danger
Dangerous goods	Stop handling; isolate safely without improvising; contact trained emergency/regulatory resources
Law-enforcement request	Verify identity and authority; preserve request; involve counsel; disclose only authorized scope
Service outage	Freeze uncertain mutations; notify support; restore; reconcile jobs, messages and payments

BREACH RULE Notification must follow a fact-based risk assessment and applicable Alberta requirements. Do not improvise or promise notification outcomes before the privacy lead and counsel review the incident.

6. Governance inventories

Proposed retention matrix

These are implementation starting points. Counsel, privacy, insurer and accountant must approve final periods.

Data	Purpose / location / access	Proposed retention	Deletion
Account, name, phone	Supabase customers/Auth; customer and authorized staff	Account life + 30 days after verified request, except holds	Delete Auth user/sessions/customer; anonymize retained transaction link
Browser draft	Device local storage	Session-only preferred; max 24 hours with explicit save	Clear after booking/logout/expiry; offer discard
Addresses + job details	Jobs; customer, assigned driver, authorized staff	Active + 24 months placeholder	Remove/anonymize unless claim/legal hold
Messages	Database and possibly SMS	24 months after job/claim close placeholder	Purge database/provider copies
Photos/videos	Private Storage	90 days after completion if no claim; claims per approved period	Delete object + metadata; verify backup expiry
Payment/tax records	Future ledger/accounting	Generally six years from relevant tax year	Keep necessary finance record; remove unrelated PII
Driver ID/licence	Future encrypted verification	Full image only as necessary; result for approved relationship period	Secure delete including vendor copy
Insurance/vehicle docs	Future verification store	Active + approved claims/audit window	Encrypted deletion; retain minimal verification event
SMS consent/opt-out	Consent ledger/provider	While relied upon + counsel-approved evidence window	Retain minimal evidence; suppress immediately
SMS body/outbox	Supabase/Twilio	Body 90 days placeholder; minimal metadata if justified	Purge body/provider copy
Security logs	Hosting/monitoring	12 months placeholder; minimize raw IP	Automated expiry and access control
Claims/accidents	Claims store	Counsel/insurer-approved period or legal hold	Closure review, release hold, secure purge
Support/privacy	Future support system	Two years after closure placeholder	Purge attachments first; minimal result audit
Rate limits/sessions	Supabase	Days for rate limits; immediate session expiry + short audit	Scheduled cleanup

Third-party inventory

Provider	Purpose / data	Current state	Main action
Netlify	UI, API, cookies, requests/IP logs, scheduled worker	Alias works; US functions; free plan; no custom domain	Canonical domain, monitoring, recovery, account MFA
Supabase	Auth, jobs, messages, sessions, outbox, private media	US West; Phone disabled; no backups/migrations shown	Phone provider, backups, staging, access review, DPA
Twilio / SMS	Phone and message body	App notification outbox not delivering	Configure, monitor, consent/STOP, minimize body
GoDaddy / DNS	Domain registration/DNS	Apex points to Netlify; site not attached; www unresolved	Account MFA, renewal lock, attach DNS/site
GitHub	Public source and deploy origin	Main matches deploy; no committed secrets found	MFA, branch protection, required checks
Interac / bank	Payment outside app	Personal email; no reconciliation	Business account, ledger, receipts, fraud controls
Maps/email/analytics/card processor	Not implemented	No provider	Select only after privacy/security review

Professional review queue

Professional	Decisions required before launch
Alberta lawyer	Terms, Internet contract, cancellation/refund, claims, platform role, driver agreement, limitation/indemnity, marketing, incident process
Privacy professional	PIPA program, privacy officer, consent, notices, cross-border providers, retention, rights, breach tabletop
Insurance broker	Commercial auto/use, CGL, cargo/bailee, cyber, claims process, exclusions, driver/vehicle evidence
Accountant	Business payment account, GST, receipts, revenue recognition, driver payouts, books/records
Transport specialist	Vehicle weights/operating area, carrier/SFC, cargo securement, TDG, maintenance/safety programs
Employment/WCB adviser	Contractor classification, actual working relationship, payroll/CPP/EI, WCB coverage and clearances

Master launch checklist

Corporate / regulatory ☐ Corporation information verified ☐ Edmonton business licence ☐ GST/tax review ☐ Commercial transport review ☐ Commercial auto/cargo/CGL/cyber insurance ☐ Worker/contractor/WCB structure	Legal ☐ Privacy Policy ☐ Terms of Service ☐ Driver Agreement ☐ Cancellation Policy ☐ Refund Policy ☐ Damage/Claims Policy ☐ Prohibited Items Policy ☐ Acceptable Use rules
Privacy ☒ Technical data inventory drafted ☐ Privacy officer ☐ Collection notices/consent ☐ Cross-border disclosure ☐ Retention/deletion ☐ Access/correction/deletion requests ☐ Vendor/DPA review ☐ Breach process	Security ☐ Working customer auth ☒ Customer/job authorization ☒ Database RLS ☒ Basic API controls ☒ No committed secrets found ☒ Private signed media ☐ File scanning/signature ☐ Named admin/driver accounts ☐ MFA/RBAC/audit logs ☒ Rate limiting ☐ Backups/restore ☐ Independent security test
Payments ☐ Business payment destination ☐ Transaction ledger ☐ Receipts/invoices/taxes ☐ Refunds/chargebacks ☐ Webhook/replay protection if added ☐ Duplicate-payment protection ☐ Driver payouts/fees ☐ Daily reconciliation	Operations ☐ Transaction-safe lifecycle ☐ Cancellation/no-show/change order ☐ Damage/claims/POD ☐ Accident/injury response ☐ Visible support/safety/privacy contacts ☐ Driver verification ☐ Working customer verification ☐ Incident tabletop ☐ Dangerous-goods controls

Master launch checklist - production and final gate

Production ☒ HTTPS on Netlify alias ☐ d-load.ca + www ☒ Current Git commit deployed ☒ Production DB connected ☐ Working OTP/SMS ☐ Staging separation ☐ Monitoring/alerts ☐ Backup/recovery/migrations/rollback ☒ Build/lint/audit passed ☐ Behavioral E2E/concurrency tests	Go / no-go approval ☐ Closure evidence attached for every F01-F15 finding ☐ Professional sign-offs attached ☐ Controlled pilot accepted ☐ Restore and rollback rehearsals passed ☐ Launch owner approval recorded ☐ Decision and effective date recorded
--	---

FINAL GATE	Public launch requires zero unresolved blockers, working authentication and messaging, recoverable production, safe privileged access, professional sign-offs, a completed controlled pilot, and documented go/no-go approval.
-------------------	--

Appendix A - Technical validation

Check	Result
Git state	main matched origin/main at 0c53682; clean worktree before PDF creation
Netlify deploy	haulway9 production commit 0c53682; scheduled sms-dispatch present
Custom domain	d-load.ca returned 404 Site not found; Netlify project had no custom domain/aliases
Live security headers	CSP, HSTS, X-Frame-Options, nosniff, referrer and permissions policy present; APIs no-store
Supabase project	Healthy, Free plan, West US/Oregon, nano compute, no backup, no registered migration, no branches
Auth provider	Phone disabled; app requires OTP; no Auth users
Database aggregate	5 customers, 1 operator, 7 sessions, 6 jobs, 8 media rows, 57 messages, 52 SMS outbox rows at audit time
SMS aggregate	52 pending, zero attempts, zero provider IDs; oldest August 14
Storage	Private job-media bucket; 25 MB per-object limit
Build/tests	Next production build, TypeScript, lint and 9 tests passed
Dependencies	0 known production vulnerabilities from npm audit --omit=dev
Secrets	No tracked secret values found; report does not reproduce any secret

Appendix B - Primary official sources

Alberta PIPA responsibilities

<https://www.alberta.ca/organization-responsibilities-for-protecting-personal-information.aspx>

Alberta collection and cross-border notice

<https://www.alberta.ca/collecting-personal-information>

Alberta Consumer Bill of Rights

<https://www.alberta.ca/consumer-bill-of-rights>

City of Edmonton business licensing

https://www.edmonton.ca/business_economy/business-licensing

Alberta commercial carrier pre-entry

<https://www.alberta.ca/pre-entry-requirements-commercial-carriers>

Transport Canada dangerous-goods competency

<https://tc.canada.ca/en/dangerous-goods/safety-awareness-materials-faq/industry/basic-competency-transporting-dangerous-goods>

CRTC CASL FAQ

<https://www.crtc.gc.ca/eng/com500/faq500.htm>

CRA GST/HST registrant guide

<https://www.canada.ca/en/revenue-agency/services/forms-publications/publications/rc4022/general-information-gst-hst-registrants.html>

CRA record retention

<https://www.canada.ca/en/revenue-agency/services/forms-publications/publications/rc188/keeping-records.html>

CRA employee or self-employed

<https://www.canada.ca/en/revenue-agency/services/tax/canada-pension-plan-cpp-employment-insurance-ei-rulings/employee-self-employed.html>

WCB Alberta contractors

<https://www.wcb.ab.ca/insurance-and-premiums/types-of-coverage/coverage-for-contractors-and-subcontractors.html>

PCI SSC CVV guidance

<https://www.pcisecuritystandards.org/faqs/1280/>

Competition Bureau deceptive marketing

<https://competition-bureau.canada.ca/en/deceptive-marketing-practices>

This report is a launch-management and risk-coordination document. It does not replace advice from qualified Alberta legal, privacy, insurance, accounting, WCB/employment, or transportation professionals.